
SCIENCES DU NUMÉRIQUE · L1 SNAF

Sécurité et vie privée en ligne

Comprendre les risques et se protéger dans un monde connecté

D'après les 27 diapositives « Protection et sécurité », Frédéric Maris, UE Sciences du Numérique, L1 SNAF, Université Toulouse III. La section « Comment se protéger » correspond à une diapositive vide dans le support et constitue une reconstitution.

Sommaire

PARTIE I · ENJEUX

01	Ce qui se passe en ligne a des effets réels.....	3
02	L'anonymat est relatif.....	3
03	Identité et vie privée	4
04	Ce que « sécurité » veut dire	4

PARTIE II · UTILISER LES OUTILS INFORMATIQUES

05	Croyance et réalité.....	5
06	Règles de bon sens.....	6
07	Lire son mail : HTTPS et TLS.....	6
08	Authentification.....	7

PARTIE III · SÉCURITÉ INFORMATIQUE

09	Une discipline développée a posteriori.....	8
10	Cryptographie à clefs publiques : chiffrer et signer.....	8
11	Les PKI : le vrai problème est la confiance	9
12	Retour sur l'exemple : l'attaque par fausse autorité	10

PARTIE IV · LES LOGICIELS MALVEILLANTS

13	Cheval de Troie, virus, ver.....	12
14	Comment se protéger ?	13

PARTIE V · OBJETS CONNECTÉS ET CAPTEURS

15	Objets connectés et capteurs.....	14
----	-----------------------------------	----

POUR RÉVISER

·	Glossaire des définitions	15
·	Synthèse	16

01 Ce qui se passe en ligne a des effets réels

diapo 3

Le cours part d'un fait divers. Un numéro de téléphone est mis en place pour les **victimes de harcèlement** ; des membres d'un forum le **sabotent** en le saturant d'appels.

Ce que l'informaticien doit en retenir

- **Ce qui se passe sur Internet a des répercussions dans la vie réelle.** Ici, des personnes en détresse n'ont pas pu joindre le service qui leur était destiné.
- **L'anonymat supposé est porteur de dérives non maîtrisées** : croire qu'on n'est pas identifiable change le comportement — et cette croyance, on va le voir, est largement fausse.

Ce que dit la loi

- le **cyber-harcèlement est puni par la loi** ;
- plus généralement, sont punis **à la fois** :
 - des comportements **se limitant aux systèmes informatiques** (par exemple l'intrusion dans un système) ;
 - des comportements jugés **d'après leur lien avec des activités hors informatique** — le sabotage d'un numéro d'aide est punissable pour ce qu'il empêche dans le monde réel, pas parce qu'il passe par un téléphone.

Autrement dit, il n'existe pas de « zone informatique » où le droit ordinaire ne s'appliquerait plus. L'écran n'est pas une frontière juridique.

02 L'anonymat est relatif

diapo 4

Reprenons le même exemple. **Au bout de trois jours**, quelqu'un a découvert qu'en saturant le numéro de téléphone, les membres du forum **laissaient une preuve de leur identité** : l'action elle-même les avait dénoncés.

Et même sans cela, il reste une voie beaucoup plus simple : **les gestionnaires de sites web et les fournisseurs d'accès peuvent dans tous les cas retrouver les personnes, sur demande de la justice**. L'anonymat en ligne est un anonymat *vis-à-vis des autres utilisateurs*, pas vis-à-vis de l'infrastructure.

TOKUTEICHU

Au Japon, des utilisateurs se sont spécialisés dans l'**identification de personnes à partir de leurs publications ou de leurs images** : on en compte de l'ordre de **500 000**.

Conséquence directe : il y est extrêmement recommandé de **changer très régulièrement son surnom** en ligne, pour éviter qu'un pseudonyme unique ne serve de fil conducteur entre toutes vos traces.

Le point important n'est pas le Japon : c'est que l'identification ne demande ni piratage ni moyens techniques particuliers. Elle demande de la **patience** et le **recoupement** d'informations publiques.

03 Identité et vie privée

diapo 5

DÉFINITION

Une **identité** est une chose liée à une **unique** personne. Connaître l'identité de quelqu'un permet d'**apprendre plein de choses** sur cette personne.

La **vie privée** — mauvaise traduction du terme anglais *privacy* — est le problème inverse : **des qualificatifs indirects peuvent être suffisants pour trouver l'identité d'une personne**. Aucun d'eux ne vous nomme ; ensemble, ils ne désignent plus que vous.

L'exemple du cours est une **photo d'arrêt de bus, sans aucun humain dessus** — le genre d'image qu'on publie sans y penser :

Chaque indice pris isolément est anodin. C'est leur **recoupement** qui produit l'identification — et c'est précisément le mécanisme contre lequel la notion de vie privée cherche à protéger.

04 Ce que « sécurité » veut dire

diapo 6

La sécurité, au sens général, c'est la **protection des personnes et des biens** :

- **protection des personnes** : respect de la vie privée, prévention de crimes contre les personnes ;
- **protection des biens** : éviter le vol ou la destruction de biens.

L'OBJECTIF DE CE COURS

- donner **quelques règles de bon sens** pour se protéger ;
- rappeler qu'**Internet est un espace partagé** : suivre ces règles permet donc aussi de **protéger les autres**.

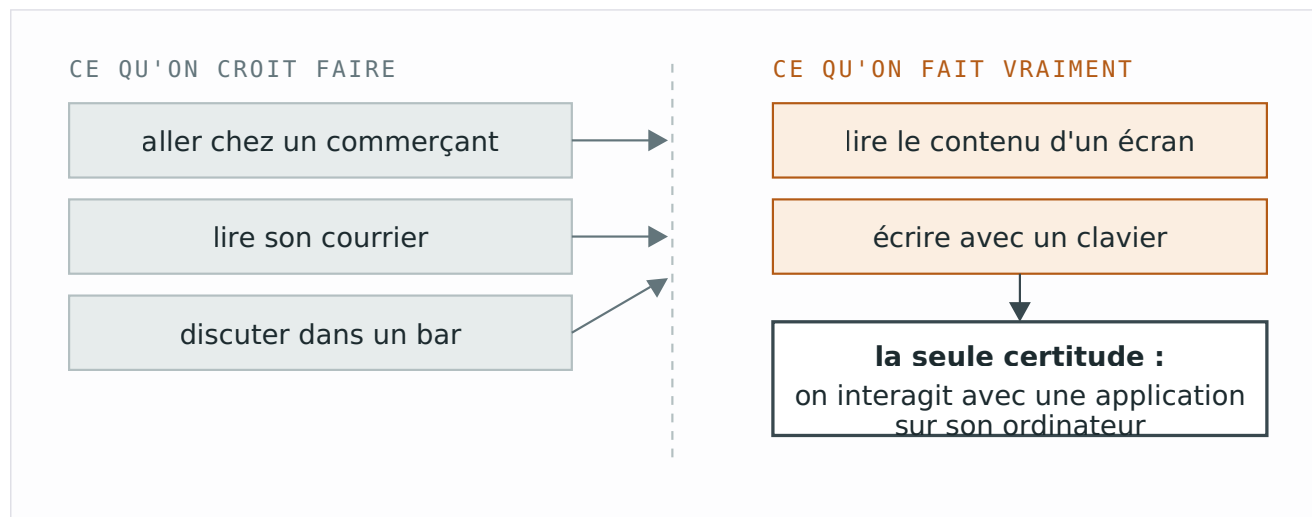
Ce dernier point mérite d'être médité : une machine mal protégée ne met pas seulement en danger son propriétaire. Elle devient un relais — pour propager un logiciel malveillant, ou pour participer, à l'insu de son propriétaire, à une attaque contre quelqu'un d'autre.

05 Croyance et réalité

diapos 7-8

La croyance. L'informatique a pour but d'être **invisible**. Elle y réussit si bien qu'on raisonne par analogie avec le monde physique : on va sur un site Internet comme on irait chez un commerçant, on lit son mail comme on lirait son courrier, on discute sur un forum comme on discuterait dans un bar.

La réalité. Dans tous ces cas, ce qu'on fait vraiment est beaucoup plus pauvre : on **lit le contenu d'un écran** et on **écrit avec un clavier** (ou en dictant).



Toutes les analogies du monde physique s'arrêtent à la même conclusion : vous ne savez pas qui est en face, vous savez seulement **quelle application tourne sur votre machine**. Tout le reste — l'identité du site, celle de votre interlocuteur — doit être **prouvé**.

Le forum n'est pas un bar

Le cours pousse la comparaison jusqu'au bout, et c'est le passage à retenir.

DANS UN BAR	SUR INTERNET
une personne que vous venez de rencontrer ne sait rien de vous	ce que vous écrivez reste écrit pour toujours
l'inverse est vrai : vous ne savez rien d'elle	tout au long de votre vie, il sera possible que des personnes fassent le lien entre ce que vous avez écrit et vous
ce qui se passe dans un bar reste dans un bar	avec le développement de l' IA , ça ne va pas s'arranger

La différence tient en deux mots : **permanence** et **recoupement**. Une conversation de bar s'efface ; un message de forum est archivé, indexé, et pourra être relié à vous par des outils qui n'existaient pas au moment où vous l'avez écrit.

06 Règles de bon sens

diapo 9

SUR LES RÉSEAUX SOCIAUX

- ✓ N'interagissez **qu'avec des personnes que vous connaissez**.
- ✓ En dehors des connaissances réelles — amis, famille — la seule bonne réponse est : « **Non, je n'utilise pas XYZ** ».

SUR LES FORUMS

- ✗ Ne comptez pas sur l'anonymat : **l'anonymat s'en va, les écrits restent**.
- ✓ Comportez-vous **comme vous le feriez dans la rue** — c'est-à-dire devant des personnes qui peuvent vous reconnaître.

La deuxième règle des réseaux sociaux surprend, mais elle est cohérente avec la section 03 : confirmer que vous utilisez tel service, c'est déjà donner un qualificatif indirect de plus à quelqu'un qui cherche à vous identifier.

07 Lire son mail : HTTPS et TLS

diapos 10-11

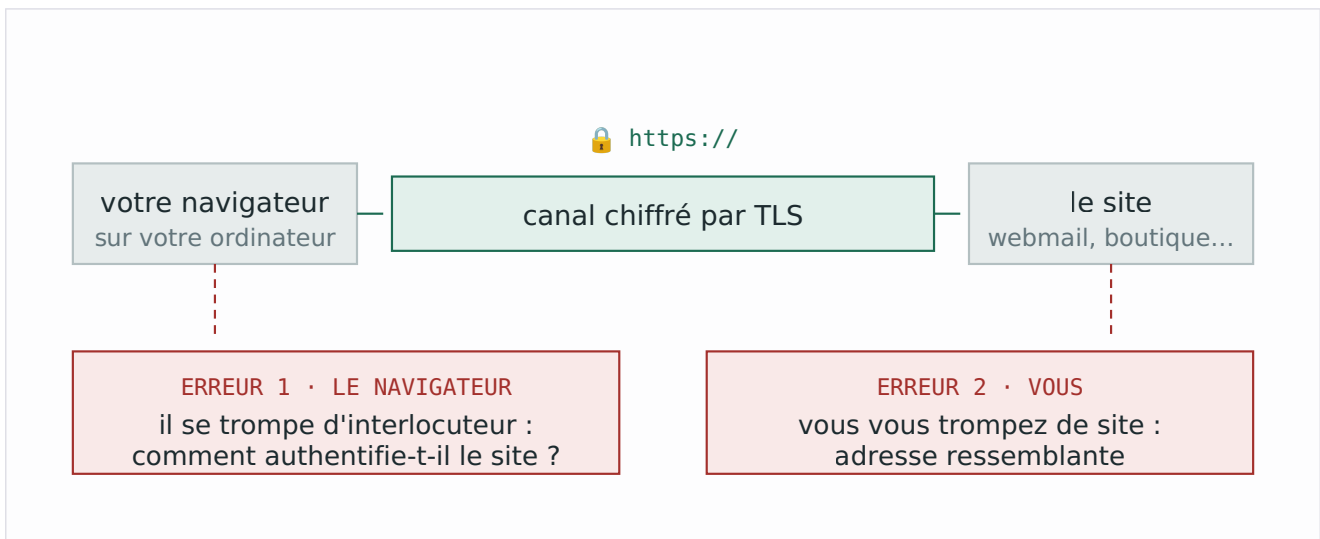
Deuxième exemple concret : le webmail de l'université. On y **rentre un login et un mot de passe** — et **ce qui se passe après dépend de beaucoup de choses**.

HTTPS

- c'est le protocole **HTTP**, celui du web ;
- dont les messages sont transmis en utilisant le protocole **TLS** (*Transport Layer Security*) pour **sécuriser l'échange** ;
- même chose pour un site marchand, où vous saisissez des coordonnées bancaires.

Ce que le cadenas signifie — et ce qu'il ne signifie pas

Quand le navigateur affiche le cadenas devant `https://...`, la signification exacte est : **d'après votre navigateur, vous êtes bien en communication sécurisée**. Cette phrase contient deux failles possibles.



Le cadenas garantit que la **communication est chiffrée** — pas qu'elle va au bon endroit. Un site frauduleux à l'adresse ressemblante peut parfaitement afficher un cadenas vert : la liaison avec l'escroc sera très bien protégée.

08 Authentification

diapo 12

DÉFINITION

Authentifier, c'est avoir une preuve de l'identité.

Trois remarques suivent cette définition, et elles portent tout le reste du cours :

- pour un site Internet, **l'identité, c'est l'adresse affichée** — d'où l'importance de l'erreur n° 2 de la section précédente ;
- on obtient une preuve en utilisant de la **cryptographie** ;
- la cryptographie est utilisée pour construire des **PKI** (infrastructures à clefs publiques) **sûres dans certaines limites**.

Retenez la nuance de la troisième remarque : « sûres *dans certaines limites* ». La partie III consiste précisément à dire où sont ces limites — et elles ne sont pas là où on les attend.

09 Une discipline développée *a posteriori*

diapo 13

L'histoire de la sécurité informatique tient en trois lignes :

- on a d'abord **vendu plein d'utilisations des ordinateurs qui facilitent la vie** ;
- on s'est ensuite rendu compte que **les vendeurs étaient beaucoup trop optimistes** ;
- la sécurité informatique est arrivée en **service après-vente**.

Cette formule explique une bonne partie des difficultés du domaine : la sécurité a été ajoutée *par-dessus* des systèmes conçus sans elle, au lieu d'être présente dès la conception.

LA SUITE DU COURS

- un exemple d'**utilisation de la cryptographie pour l'authentification** ;
- les **logiciels malveillants** et les **risques liés aux objets connectés**.

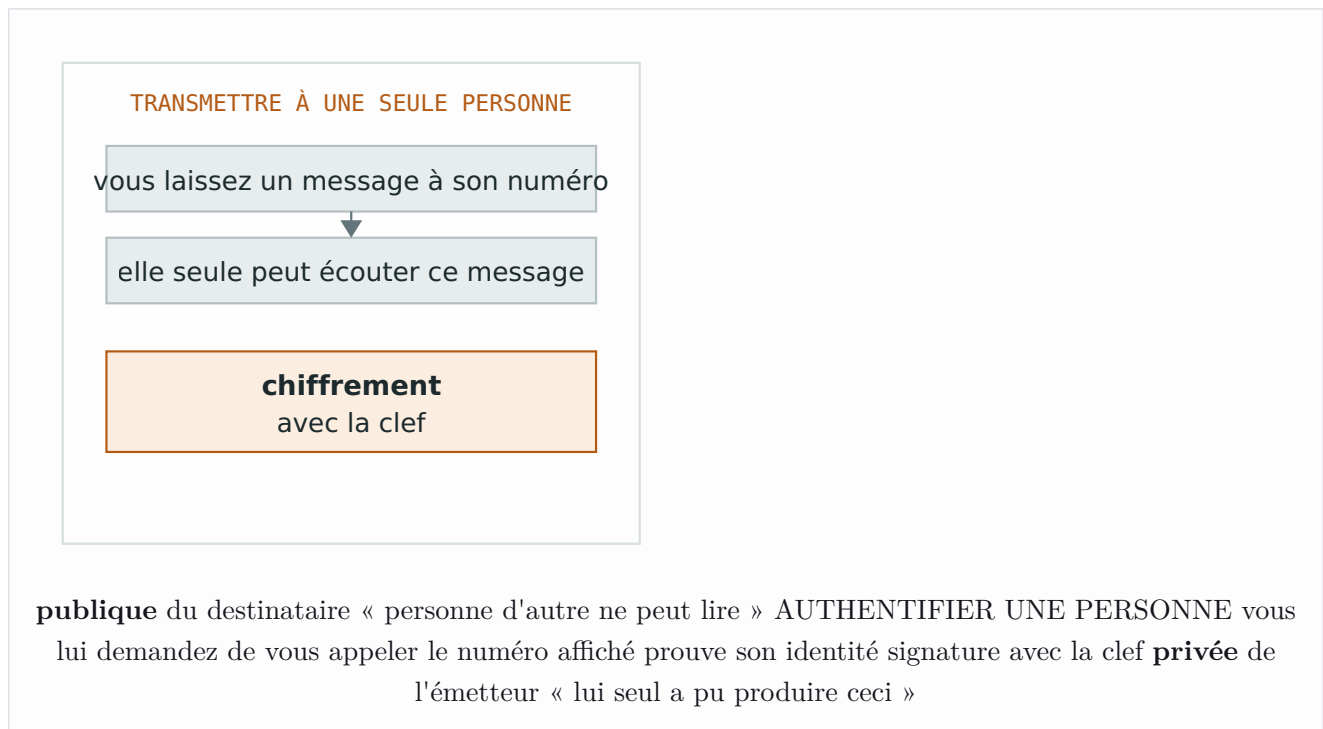
10 Cryptographie à clefs publiques : chiffrer et signer

diapo 14

Le cours propose une analogie qu'il faut retenir telle quelle, parce que les deux usages de la cryptographie s'en déduisent sans effort.

L'ANALOGIE DU TÉLÉPHONE

- une **clef secrète** (ou privée) : un **téléphone greffé sur vous** — personne d'autre ne peut s'en servir ;
- une **clef publique** : le **numéro** de ce téléphone — tout le monde peut le connaître.



Le sens dans lequel on utilise la paire de clefs décide de la propriété obtenue : la clef **publique du destinataire** sert à **chiffrer** (confidentialité), la clef **privée de l'émetteur** sert à **signer** (authenticité). C'est le seul point à ne pas confondre.

11 Les PKI : le vrai problème est la confiance

diapos 15-17

L'analogie du téléphone laisse une question en suspens : **et l'annuaire ?** Pour qu'elle fonctionne, il faut deux choses :

- que **l'affichage du numéro et l'écoute des messages marchent correctement** — c'est le rôle de la technique ;
- pouvoir **associer avec certitude une personne à un numéro de téléphone** — et c'est une toute autre affaire.

CRYPTOGRAPHIE

- c'est la **discipline qui assure techniquement les propriétés du chiffrement et de la signature** ;
- les principaux problèmes actuels concernent **l'efficacité des méthodes plus que leur sécurité**.

INFRASTRUCTURE À CLEFS PUBLIQUES (PKI)

C'est un **annuaire associant une clef publique à une personne**.

Le problème n'est pas la cryptographie, mais **en qui on a confiance**.

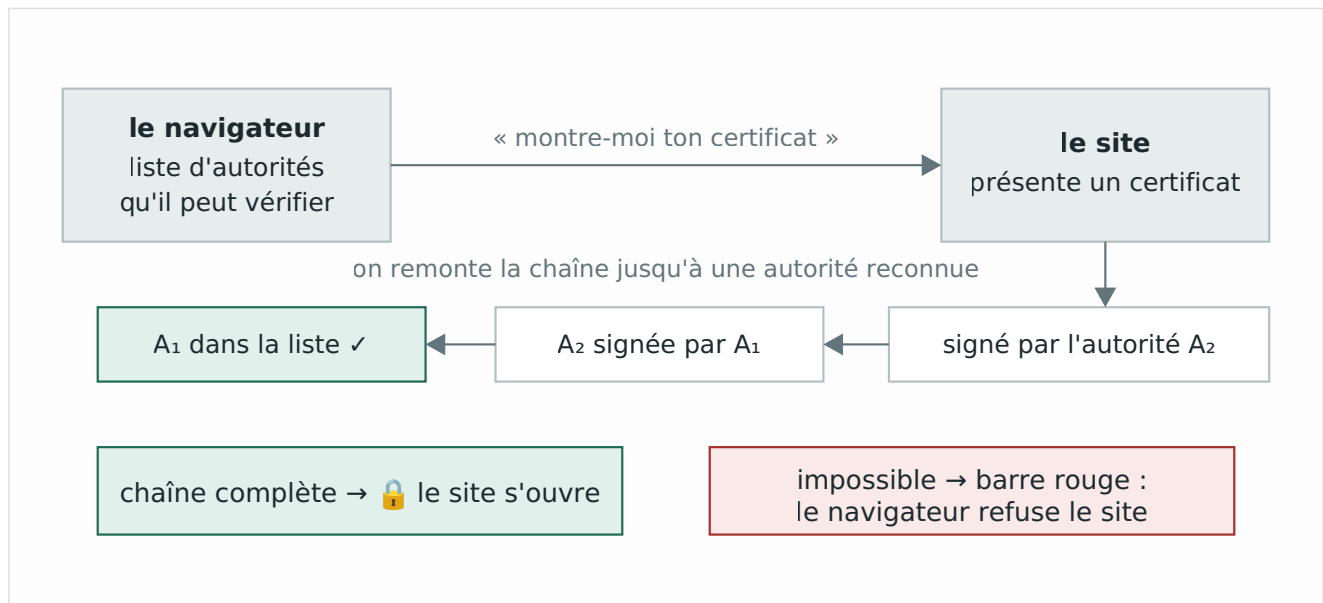
Certificats et autorités

La brique de base d'une PKI est un énoncé signé, appelé **certificat** :

TYPE	ÉNONCÉ
Certificat	l'autorité A certifie que la clef K est associée à l'identité B
Certificat auto-signé	l'autorité B certifie que la clef K est associée à l'identité B

La différence est cruciale : dans le second cas, c'est l'intéressé lui-même qui affirme son identité. Un certificat auto-signé ne prouve donc rien à un inconnu — c'est l'équivalent d'une carte d'identité fabriquée à la maison.

Ce que fait votre navigateur



Chaque navigateur est livré avec une **liste d'autorités** qu'il sait vérifier. Si l'autorité qui a signé le certificat du site n'y figure pas, il demande à vérifier la clef de cette autorité, et ainsi de suite **jusqu'à arriver à une autorité reconnue**. Si ce n'est pas possible : barre rouge.

12 Retour sur l'exemple : l'attaque par fausse autorité

diapo 18

Toute la construction précédente repose sur un seul élément : **la liste d'autorités présente dans votre navigateur**. Si quelqu'un contrôle cette liste, il contrôle ce que le cadenas veut dire.

L'ATTAQUE

- quelqu'un peut **modifier votre ordinateur pour y ajouter une autorité** qui délivrera de **faux certificats** ;
- exemple commun : **l'entreprise dans laquelle vous travaillez**, sur l'ordinateur qu'elle vous fournit ;
- ce n'est pas toujours le cas, mais **ça arrive**.

Conséquence pratique : sur une machine que vous ne contrôlez pas, le cadenas ne prouve plus rien vis-à-vis du propriétaire de la machine. Il continue de vous protéger d'un attaquant extérieur, mais pas de celui qui a installé l'autorité.

LA BOUCLE EST BOUCLÉE

Retour à la définition de la section 08 : authentifier, c'est **avoir une preuve de l'identité**. Une preuve n'a de valeur que si l'on fait confiance à celui qui la délivre — d'où la formule du cours : **le problème n'est pas la cryptographie, mais en qui on a confiance**.

13 Cheval de Troie, virus, ver

diapos 19–22

Il existe plusieurs types de **logiciels malveillants** (*malware*). Le cours en distingue trois, qu'il ne faut pas confondre : ils se différencient par **la façon dont ils arrivent et se propagent**, pas par ce qu'ils font une fois en place.

Le cheval de Troie (*Trojan horse*)

DÉFINITION

Un **logiciel en apparence inoffensif, mais qui contient une fonctionnalité malveillante**.

Son objectif est d'**installer un parasite** :

- un **logiciel espion** (*spyware*) ;
- ou un **virus**.

Le cours ajoute un avertissement concret : **les logiciels crackés peuvent être des chevaux de Troie**. C'est logique — quelqu'un a passé du temps à modifier un programme puis à vous le distribuer gratuitement ; la question à se poser est ce qu'il y gagne.

Le virus informatique

DÉFINITION

Les **virus** sont capables de **se répliquer**, puis de **se propager à d'autres ordinateurs en s'insérant dans d'autres programmes ou documents légitimes** appelés « hôtes ».

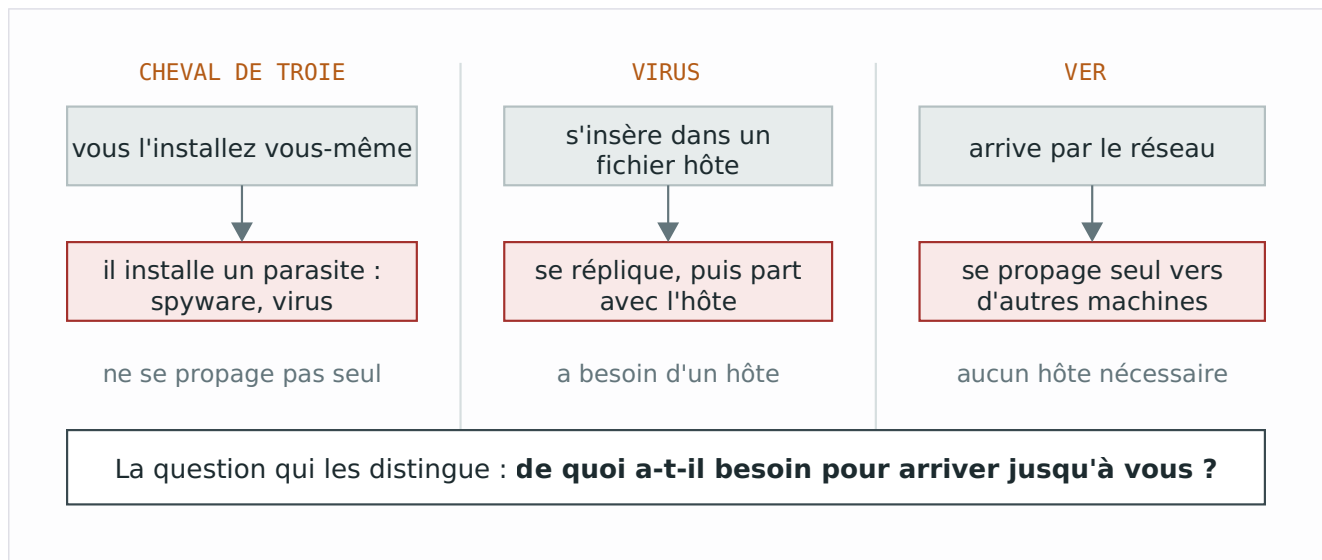
Différents types de virus : de **secteur d'amorçage**, de **fichier**, de **macro**, et de **script**.

Le ver informatique (*worm*)

DÉFINITION

Un **ver** n'a **pas besoin d'un support physique ou logique** — disque dur, programme hôte, fichier... — pour se propager. Un ver peut être considéré comme un **virus réseau**.

Différents types de vers : de **réseau**, de **courrier électronique**, de **messagerie instantanée**, d'**Internet**, et de **réseaux de partage de fichiers**.



Le cheval de Troie a besoin de **vous** ; le virus a besoin d'un **hôte** ; le ver n'a besoin de **rien** — d'où sa vitesse de propagation, et le fait qu'on le décrive comme un virus réseau.

14 Comment se protéger ?

diapo 23

NOTE

Cette diapositive est **vide dans le support** : elle correspond à une discussion orale. Ce qui suit est une reconstitution appuyée sur les règles et les mécanismes vus dans le reste du cours — à confronter avec ce qui a été dit en amphi.

- ✓ **Mettre à jour** système et applications : les vers exploitent des failles connues et déjà corrigées.
- ✓ **N'installer que des logiciels d'origine sûre** — le cours vise explicitement les logiciels crackés, chevaux de Troie typiques.
- ✓ **Se méfier des pièces jointes et des liens**, même venant d'un contact : les vers de courrier électronique se propagent précisément ainsi.
- ✓ **Vérifier l'adresse** avant de saisir un mot de passe, plutôt que le seul cadenas : l'identité d'un site, c'est son adresse (section 08).
- ✓ **Sauvegarder** ses données : la seule protection qui fonctionne encore une fois la machine compromise.
- ✗ Ne pas considérer qu'une machine fournie par un tiers est un environnement de confiance (section 12).

15 Objets connectés et capteurs

diapos 24–26

DÉFINITION

Un **objet connecté** est un **matériel électronique qui peut communiquer** avec un smartphone, une tablette tactile, une montre, un ordinateur ou une télévision.

Les risques

- **Utilisation commerciale des données personnelles et atteintes à la vie privée.** Nous laissons de plus en plus de **traces numériques** ; l'enjeu est désormais de parvenir à **garantir l'anonymat des données collectées** par ces appareils.
- **Piratage.** Dès lors que se connecter à Internet devient une fonction intégrante d'objets du quotidien, leurs concepteurs doivent faire face aux risques de « cyber » attaque — sur des objets qui, eux, n'ont pas été conçus par des spécialistes de la sécurité.

UN RISQUE AVÉRÉ

Septembre 2017 : l'attaque BlueBorne — exécution de code et téléchargement de données personnelles sur des appareils connectés (enceintes et assistants vocaux notamment).

Dans un monde de capteurs

Le dernier point du cours est le plus concret : chaque appareil que vous portez contient des capteurs, et chacun d'eux répond à une question sur vous.

CAPTEUR	CE QUE DIT LE COURS	CE QU'IL RÉVÈLE
La caméra	si vous autorisez une application à y accéder, elle pourra prendre des photos ou enregistrer et transmettre des films même lorsqu'elle s'exécute en tâche de fond	votre environnement, les personnes présentes
Le microphone	« OK Google », « Dis Siri », « Alexa »... les assistants personnels vous écoutent en permanence (uniquement ?) pour répondre à vos attentes	vos conversations, qui est là
Les autres	GPS, gyroscope, boussole...	où vous êtes, comment vous vous déplacez, dans quelle direction vous regardez

La parenthèse « (uniquement ?) » du support est l'essentiel de la diapositive : un micro qui doit entendre son mot d'activation est, par construction, **un micro allumé en permanence**. Ce qu'il fait du reste dépend entièrement de la confiance qu'on accorde au constructeur — on retrouve exactement la conclusion de la partie III.

→ Glossaire des définitions

Identité diapo 5	Une chose liée à une unique personne. La connaître permet d'apprendre beaucoup de choses sur cette personne.
Vie privée (<i>privacy</i>) diapo 5	Le problème inverse : des qualificatifs indirects peuvent suffire à retrouver l'identité de quelqu'un.
Sécurité diapo 6	Protection des personnes (vie privée, prévention des crimes) et des biens (vol, destruction).
HTTPS diapo 10	Le protocole HTTP dont les messages sont transmis via TLS pour sécuriser l'échange.
TLS diapo 10	<i>Transport Layer Security</i> : le protocole qui sécurise le transport des messages.
Authentifier diapo 12	Avoir une preuve de l'identité. Pour un site Internet, l'identité c'est l'adresse affichée.
Clef secrète (privée) diapo 14	Dans l'analogie du cours : un téléphone greffé sur vous. Sert à signer .
Clef publique diapo 14	Le numéro de ce téléphone, connu de tous. Sert à chiffrer à destination de son propriétaire.
Cryptographie diapo 15	La discipline qui assure techniquement les propriétés du chiffrement et de la signature. Ses problèmes actuels tiennent plus à l'efficacité qu'à la sécurité.
PKI diapo 16	Infrastructure à clefs publiques : un annuaire associant une clef publique à une personne. Le problème n'est pas la cryptographie, mais en qui on a confiance.
Certificat diapo 17	Énoncé : l'autorité A certifie que la clef K est associée à l'identité B.
Certificat auto-signé diapo 17	L'autorité B certifie que la clef K est associée à l'identité B : l'intéressé se certifie lui-même.
Cheval de Troie diapo 20	Logiciel en apparence inoffensif contenant une fonctionnalité malveillante ; son objectif est d'installer un parasite (spyware, virus).
Virus diapo 21	Logiciel capable de se répliquer et de se propager en s'insérant dans des programmes ou documents légitimes appelés hôtes.
Ver (<i>worm</i>) diapo 22	Logiciel qui se propage sans avoir besoin d'un support physique ou logique : un virus réseau.
Objet connecté diapo 24	Matériel électronique capable de communiquer avec un smartphone, une tablette, une montre, un ordinateur ou une télévision.

→ Synthèse

Les cinq parties disent la même chose sous cinq angles : **ce qui paraît invisible, gratuit ou anonyme ne l'est pas**. Les écrits restent, les indices se recoupent, le cadenas ne prouve que ce que votre machine veut bien croire, un logiciel gratuit a un modèle économique, et un micro qui attend un mot d'activation est un micro allumé.

QUESTION À SE POSER	CE QUE LE COURS RÉPOND
Suis-je anonyme ?	Vis-à-vis des autres utilisateurs, en partie. Vis-à-vis des sites et des FAI, non — et sur demande de la justice, jamais.
Cette photo est-elle anonyme ?	Aucun indice n'identifie seul ; c'est leur recoupement qui identifie.
Le cadenas suffit-il ?	Il prouve que l'échange est chiffré. Il ne prouve pas que vous parlez au bon site, ni que la liste d'autorités de votre machine est saine.
Ce logiciel gratuit est-il sûr ?	Un logiciel cracké peut être un cheval de Troie ; demandez-vous ce que gagne celui qui le distribue.
Ce malware, comment est-il arrivé ?	Par vous (cheval de Troie), par un hôte (virus), ou tout seul par le réseau (ver).
Cet objet connecté me surveille-t-il ?	Il en a les moyens techniques ; la réponse dépend de la confiance accordée à son concepteur.

LA PHRASE À RETENIR

« **Le problème n'est pas la cryptographie, mais en qui on a confiance.** » Elle vaut pour les certificats, mais aussi pour les applications qu'on autorise, les objets qu'on installe chez soi et les machines qu'on nous fournit.